UNIVERSIDAD TECNOLÓGICA INTERCONTINENTAL

Ley 822 del 12/01/96
La Universidad sin Fronteras
SEDE: ÑEMBY

CRITERIOS TECNICOS DE EVALUACION DE LA SEGURIDAD DEL SISTEMA

Docente: Dr. Cristian David Macen Rojas
Nombre del Alumno/a: _____CI:_____
Tema del proyecto: _____

Autenticación Segura:	Logrado	Observación
Descripción: Verificar si el sistema implementa métodos de autenticación robustos para proteger el acceso de usuarios no autorizados.		
Indicadores: Autenticación multifactor (MFA), políticas de contraseñas fuertes (longitud, complejidad, expiración), y almacenamiento seguro de contraseñas (hashing).		
Control de Acceso y Gestión de Privilegios:		
Descripción: Evaluar si el sistema aplica correctamente los controles de acceso basados en roles (RBAC) y permisos, asegurando que los usuarios solo accedan a los recursos permitidos.		
Indicadores: Implementación de roles y privilegios adecuados, auditoría de accesos, y administración eficaz de permisos mínimos necesarios.		
Cifrado de Datos:		
Descripción: Verificar que los datos sensibles sean cifrados tanto en tránsito como en reposo para evitar su exposición en caso de ataques.		
Indicadores: Uso de TLS/SSL en las comunicaciones, cifrado de datos con AES o RSA, y manejo seguro de claves de cifrado.		
Manejo de Vulnerabilidades y Parches de Seguridad:		
Descripción: Evaluar si el sistema realiza un monitoreo continuo de vulnerabilidades y si aplica los parches de seguridad de forma oportuna.		
Indicadores: Pruebas de vulnerabilidad frecuentes, procesos de actualización rápidos para parches críticos, y alertas sobre nuevas amenazas.		
Protección contra Inyecciones de Código:		
Descripción: Comprobar que el sistema prevenga ataques de inyección, como SQL Injection, Cross-Site Scripting (XSS) y Command Injection.		
Indicadores: Validación y sanitización adecuada de las entradas de usuario, consultas SQL preparadas, y uso de frameworks seguros.		
Seguridad en el Manejo de Sesiones:		
Descripción: Verificar que el sistema maneje adecuadamente las sesiones de usuario, evitando ataques como secuestro de sesión y garantizando la finalización de sesiones inactivas.		
Indicadores: Expiración automática de sesiones, tokens de sesión seguros (JWT), y uso de HTTPS para proteger sesiones.		
Registro de Actividades y Monitoreo:		
Descripción: Evaluar si el sistema registra adecuadamente los eventos importantes y si se monitoriza en busca de actividad sospechosa.		
Indicadores: Logs detallados de acceso y eventos, monitoreo en tiempo real, y generación de alertas ante posibles incidentes de seguridad.		
Protección contra Ataques de Denegación de Servicio (DoS/DDoS):		
Descripción: Comprobar si el sistema tiene medidas para prevenir o mitigar ataques de denegación de servicio que puedan afectar su disponibilidad.		
Indicadores: Uso de firewalls y filtros de tráfico, servicios de mitigación de DDoS, y balanceo de carga.		
Seguridad en Copias de Respaldo y Recuperación de Datos:		
Descripción: Evaluar si el sistema realiza copias de seguridad de manera segura y garantiza la recuperación de datos en caso de incidentes.		
Indicadores: Backups automáticos y cifrados, pruebas de recuperación periódicas, y almacenamiento seguro de las copias de seguridad.		
Cumplimiento de Normativas y Estándares de Seguridad:		
Descripción: Verificar que el sistema cumpla con las normativas y estándares aplicables a la seguridad, como GDPR, ISO 27001, PCI DSS, entre otros.		
Indicadores: Auditorías de cumplimiento, políticas documentadas de seguridad, y evidencias de conformidad con regulaciones vigentes.		

Observación: Es importante que los criterios de evaluación estén completamente logrados.

Firma y sello de aprobación del Docente Fecha de evaluación: _____